

Big Data Security and Privacy

Cyber Security Essentials

Lecture 1-1 (Module 1, Lecture 1)

Dr. Bhavani Thuraisingham

The University of Texas at Dallas

June – August 2026

Overview

- 0 **What is Cyber Security?**
- 0 **What is C. I. A.?**
- 0 **Ten Major Modules of Cyber Security**
- 0 **Reference: CISSP All-in-One Exam Guide, Eighth Edition 8th Edition, McGraw Hill, Shon Harris and Fernando Maymi, 2018**
- 0 **ISC2 Lecture Notes on CISSP has also influenced this presentation**
- 0 **The lectures notes are used for educational purposes only**

Cyber Security

- 0 **Security traditionally has been about CIA (Confidentiality, Integrity, Availability)**
- 0 **Security now also includes areas like Trustworthiness, Quality, Privacy**
- 0 **Dependability includes Security, Reliability and Fault Tolerance**
- 0 **Initially the term used was Computer Security (Compusec); it then evolved into Infosec – Information security – to include data and networks – now with web its called Cyber Security**

C. I.A.

- 0 **Confidentiality: Preventing from unauthorized disclosure**
- 0 **Integrity: Preventing from unauthorized modification**
- 0 **Availability: Preventing denial of service**

Topic Covered: Ten Major Modules of Cyber Security

- 0 Information Security and Risk Management
- 0 Security Architecture and Design
- 0 Cryptography
- 0 Access Control
- 0 Telecommunications Security
- 0 Legal Regulations, Compliance and Investigations
- 0 Physical and Environmental Security
- 0 Business Continuity Planning
- 0 Operations Security
- 0 Database, Applications Security
- 0 We will focus on the first four topics
- 0 Topics not covered include some of the more recent developments including Cloud Computing Security, Social Media Security, Trustworthy Machine Learning, Secure Internet of Things, - - - -

Information Governance and Risk Management

- 0 **Security Management, Administration and Governance**
- 0 **Policies, Standards, Guidelines, Procedures**
- 0 **Information Classification**
- 0 **Roles and Responsibilities**
- 0 **Risk Management and Analysis**
- 0 **Best Practices**

Security Management, Administration and Governance

- 0 **Information security (ISec)** describes activities that relate to the protection of information and information infrastructure assets against the risks of loss, misuse, disclosure or damage.
- 0 **Information security management (ISM)** describes controls that an organization needs to implement to ensure that it is sensibly managing these risks.
- 0 **The risks to these assets can be calculated by analysis of the following issues:**
 - 0 ***Threats to your assets:*** These are unwanted events that could cause the deliberate or accidental loss, damage or misuse of the assets
 - 0 ***Vulnerabilities:*** How susceptible your assets are to attack
 - 0 ***Impact:*** The magnitude of the potential loss or the seriousness of the event.

Policies, Standards, Guidelines and Procedures

- 0 Policies are the top tier of formalized security documents.
 - Example all emails must be encrypted
- 0 Standards are tactical documents because they lay out specific steps or processes required to meet a certain requirement.
 - As an example, **AES 256 standard is used for encryption**
- 0 A *baseline* is a minimum level of security that a system, network, or device must adhere (e.g, TCSEC C2 level of assurance)
- 0 A *guideline* is a recommendation or suggestion of how things should be done.
- 0 A *procedure* is a detailed, in-depth, step-by-step document that details exactly what is to be done.

Information Classification

- 0 **It is essential to classify information according to its actual value and level of sensitivity in order to deploy the appropriate level of security.**
- 0 **A system of classification should ideally be simple to understand (e.g., not have 100 different security levels)**
- 0 **Military security levels: TopSecret, Secret, Confidential, Unclassified**
- 0 **Company security levels: Company proprietary**
- 0 **Other levels: Public or Private**

Roles and Responsibilities

0 Internal Roles

- **Executive Management; Information System Security Professionals; Owners: Data and System Owners; Custodians**
- **Operational Staff; Users; Legal, Compliance and Privacy Officers; Internal Auditors; Physical Security Officers**

0 External Roles

- **Vendors and Supplies; Contractors; Temporary Employees; Customers; Business Partners; Outsourced Relationships; Outsourced Security**

0 Human Resources

- **Employee development and management; Hiring and termination; Signed employee agreements; Education**

Risk Management and Analysis

- 0 Risk is the likelihood that something bad will happen that causes harm to an informational asset (or the loss of the asset).
- 0 A vulnerability is a weakness that could be used to endanger or cause harm to an informational asset.
- 0 A threat is anything (man made or act of nature) that has the potential to cause harm.
- 0 The likelihood that a threat will use a vulnerability to cause harm creates a risk.
- 0 When a threat does use a vulnerability to inflict harm, it has an impact.
- 0 In the context of information security, the impact is a loss of availability, integrity, and confidentiality, and possibly other losses (lost income, loss of life, loss of real property).
- 0 It should be pointed out that it is not possible to identify all risks, nor is it possible to eliminate all risk.
- 0 The remaining risk is called *residual risk*.
- 0 A risk assessment is carried out by a team of people who have knowledge of specific areas of the business.
- 0 The assessment may use a subjective **qualitative analysis** based on informed opinion (scenarios), or where reliable dollar figures and historical information is available, the analysis may use **quantitative analysis**
- 0 For any given risk, Executive Management can choose to accept the risk or mitigate it (e.g., cyber risk insurance)

Risk Management and Analysis

- 0 **Reference: CISSP Reference Book and ISC2 Lecture Notes on CISSP**
- 0 **Step 1: Estimate Potential Loss**
 - **$SLE = AV (\$) \times EF (\%)$**
 - **SLE: Single Loss Expectancy, AV: Asset Value. EF: Exposure Factor (percentage of asset value)**
- 0 **Step 2: Conduct Threat Likelihood Analysis**
 - **ARO Annual Rate of Occurrence**
 - **Number of times per year that an incident is likely to occur**
- 0 **Step 3: Calculate ALE**
 - **ALE: Annual Loss Expectancy**
 - **$ALE = SLE \times ARO$**

Security Best Practices

- 0 **Job Rotation**
- 0 **Separation of Duty**
- 0 **Security Awareness training**
- 0 **Ethics Education**

Access Control

- 0 **Access control is a system which enables an authority to control access to areas and resources in a given physical facility or computer-based information system.**
- 0 **In computer security, access control usually includes authentication, authorization and audit.**
- 0 **It also includes measures such as physical devices, including biometric scans and metal locks, hidden paths, digital signatures, encryption, social barriers, and monitoring by humans and automated systems.**
- 0 **In any access control model, the entities that can perform actions in the system are called subjects, and the entities representing resources to which access may need to be controlled are called objects.**
- 0 **Subjects and objects should both be considered as software entities and as human users**

Access Control Models

- 0 **Access control models used by current systems tend to fall into one of two classes: those based on capabilities and those based on access control lists (ACLs).**
- 0 **In a capability-based model, holding an unforgeable reference or *capability* to an object provides access to the object**
- 0 **Access is conveyed to another party by transmitting such a capability over a secure channel.**
- 0 **In an ACL-based model, a subject's access to an object depends on whether its identity is on a list associated with the object.**

Identification, Authentication, Authorization

- 0 **Access control systems provide the essential services of *identification and authentication (I&A)*, *authorization*, and *accountability* where:**
 - 0 **Identification and authentication determine who can log on to a system, and the association of users with the software subjects that they are able to control as a result of logging in;**
 - 0 **Authorization determines what a subject can do;**
 - 0 **Accountability identifies what a subject (or all subjects associated with a user) did.**

Identification, Authentication, Authorization

- 0 **Authenticators are commonly based on at least one of the following four factors:**
- 0 ***Something you know*, such as a password or a personal identification number (PIN).**
- 0 **This assumes that only the owner of the account knows the password or PIN needed to access the account.**
- 0 ***Something you have*, such as a smart card or security token. This assumes that only the owner of the account has the necessary smart card or token needed to unlock the account.**
- 0 ***Something you are*, such as fingerprint, voice, retina, or iris characteristics.**
- 0 ***Where you are*, for example inside or outside a company firewall, or proximity of login location to a personal GPS device.**

Identification, Authentication, Authorization

- 0 **Authorization applies to subjects.**
- 0 **Authorization determines what a subject can do on the system.**
- 0 **Most modern operating systems define sets of permissions that are variations or extensions of three basic types of access:**
 - 0 **Read (R): The subject can**
 - **Read file contents, List directory contents**
 - 0 **Write (W): The subject can change the contents of a file or directory with the following tasks:**
 - **Add, Create, Delete, Rename**
 - 0 **Execute (X): If the file is a program, the subject can cause the program to be run.**

Single Sign-On

- 0 **Single sign-on (SSO) is a property of access control of multiple, related, but independent software systems.**
- 0 **With this property a user logs in once and gains access to all systems without being prompted to log in again at each of them.**
- 0 **Single sign-off is the reverse property whereby a single action of signing out terminates access to multiple software systems.**
- 0 **As different applications and resources support different authentication mechanisms, single sign-on has to internally translate to and store different credentials compared to what is used for initial authentication.**

Single Sign-on Kerberos

- 0 **Kerberos is a computer network authentication protocol, which allows nodes communicating over a non-secure network to prove their identity to one another in a secure manner.**
- 0 **It is also a suite of free software published by MIT that implements this protocol.**
- 0 **Its designers aimed primarily at a client–server model, and it provides mutual authentication — both the user and the server verify each other's identity.**
- 0 **Kerberos protocol messages are protected against eavesdropping and replay attacks.**
- 0 **Kerberos builds on symmetric key cryptography and requires a trusted third party, and optionally may use public-key cryptography by utilizing asymmetric key cryptography during certain phases of authentication**

Kerberos

- 0 Kerberos uses as its basis the symmetric Needham-Schroeder protocol. It makes use of a trusted third party, termed a key distribution center (KDC), which consists of two logically separate parts: an Authentication Server (AS) and a Ticket Granting Server (TGS). Kerberos works on the basis of "tickets" which serve to prove the identity of users.
- 0 The KDC maintains a database of secret keys; each entity on the network — whether a client or a server — shares a secret key known only to itself and to the KDC. Knowledge of this key serves to prove an entity's identity.
- 0 For communication between two entities, the KDC generates a session key which they can use to secure their interactions.
- 0 The security of the protocol relies heavily on participants maintaining loosely synchronized time and on short-lived assertions of authenticity called *Kerberos tickets*.

Kerberos

- 0 The client authenticates itself to the Authentication Server and receives a ticket. (All tickets are time-stamped.)
- 0 It then contacts the Ticket Granting Server, and using the ticket it demonstrates its identity and asks for a service.
- 0 If the client is eligible for the service, then the Ticket Granting Server sends another ticket to the client.
- 0 The client then contacts the Service Server, and using this ticket it proves that it has been approved to receive the service.

Kerberos: Drawbacks

- 0 **Single point of failure:** It requires continuous availability of a central server. When the Kerberos server is down, no one can log in.
 - This can be mitigated by using multiple Kerberos servers and fallback authentication mechanisms.
- 0 Kerberos requires the clocks of the involved hosts to be synchronized.
- 0 The tickets have a time availability period and if the host clock is not synchronized with the Kerberos server clock, the authentication will fail.
- 0 In practice Network Time Protocol daemons are usually used to keep the host clocks synchronized.
- 0 Since all authentication is controlled by a centralized KDC, compromise of this authentication infrastructure will allow an attacker to impersonate any user.

Types of Access Control

- 0 Access control techniques are sometimes categorized as either discretionary or non-discretionary.
 - The three most widely recognized models are Discretionary Access Control (DAC), Mandatory Access Control (MAC), and Role Based Access Control (RBAC). MAC and RBAC are both non-discretionary.
 - **More recently we have Attribute-based access control (ABAC)**
- 0 In attribute-based access control, access is granted not based on the rights of the subject associated with a user after authentication, but based on attributes of the user.
 - The user has to prove so called claims about his attributes to the access control engine.
 - An attribute-based access control policy specifies which claims need to be satisfied in order to grant access to an object.
 - For instance the claim could be "older than 18" . Any user that can prove this claim is granted access.

Types of Access Control

- 0 **Discretionary access control: (DAC)** is an access policy determined by the owner of an object.
- 0 The owner decides who is allowed to access the object and what privileges they have.
- 0 Two important concepts in DAC are:
 - **File and data ownership:** Every object in the system has an *owner*.
 - = In most DAC systems, each object's initial owner is the subject that caused it to be created.
 - = The access policy for an object is determined by its owner.
 - **Access rights and permissions:** These are the controls that an owner can assign to other subjects for specific resources.
- 0 Access controls may be discretionary in ACL-based or capability-based access control systems.

Types of Access Control

- 0 **Mandatory access control: (MAC)** is an access policy determined by the system, not the owner. MAC is used in multilevel systems that process highly sensitive data, such as classified government and military information.
 - A multilevel system is a single computer system that handles multiple classification levels between subjects and objects.
- 0 **Sensitivity labels:** In a MAC-based system, all subjects and objects must have labels assigned to them.
 - A subject's sensitivity label specifies its level of trust.
 - An object's sensitivity label specifies the level of trust required for access.
 - In order to access a given object (**for reading**), the subject must have a sensitivity level equal to or higher than the requested object.
 - **For writing it is the opposite (star * property)**

Types of Access Control

- 0 **Role-based access control: (RBAC)** is an access policy determined by the system, not the owner.
- 0 **RBAC** is used in commercial applications and also in military systems, where multi-level security requirements may also exist.
- 0 **RBAC** differs from **DAC** in that **DAC** allows users to control access to their resources, while in **RBAC**, access is controlled at the system level, outside of the user's control.
- 0 Although **RBAC** is non-discretionary, it can be distinguished from **MAC** primarily in the way permissions are handled.
- 0 **MAC** controls read and write permissions based on a user's clearance level and additional labels.
- 0 **RBAC** controls collections of permissions that may include complex operations such as an e-commerce transaction, or may be as simple as read or write. (**role of a professor, role of a student**)
- 0 A role in **RBAC** can be viewed as a set of permissions.

What is Biometrics?

- 0 **Biometrics are automated methods of recognizing a person based on a physiological or behavioral characteristic**
- 0 **Features measured: Face, Fingerprints, Hand geometry, handwriting, Iris, Retinal, Vein and Voice**
- 0 **Identification and personal certification solutions for highly secure applications**
- 0 **Numerous applications: medical, financial, child care, computer access etc.**
- 0 **Biometrics replaces Traditional Authentication Methods**
- 0 **Provides better security**
- 0 **More convenient**
- 0 **Better accountability**
- 0 **Applications on Fraud detection and Fraud deterrence**
- 0 **Dual purpose: Cyber Security and National Security**

What is the Process?

- 0 **Three-steps: Capture-Process-Verification**
- 0 **Capture:** A raw biometric is captured by a sensing device such as fingerprint scanner or video camera
- 0 **Process:** The distinguishing characteristics are extracted from the raw biometrics sample and converted into a processed biometric identifier record
 - Called biometric sample or template
- 0 **Verification and Identification**
 - Matching the enrolled biometric sample against a single record; is the person really what he claims to be?
 - Matching a biometric sample against a database of identifiers

Why Biometrics?

- 0 **Authentication mechanisms often used are User ID and Passwords**
- 0 **However password mechanisms have vulnerabilities: Stealing passwords**
- 0 **Biometrics systems are less prone to attacks**
- 0 **Need sophisticated techniques for attacks**
 - **Cannot steal facial features and fingerprints**
 - **Need sophisticated image processing techniques for modifying facial features**
- 0 **Biometrics systems are more convenient, Need not have multiple passwords or difficult passwords**
- 0 **Need not carry any cards or tokens**
- 0 **Better accountability: Can determine who accessed the system with less complexity**

Security Vulnerabilities

- 0 **Type 1 attack: present fake biometric such a synthetic biometric**
- 0 **Type 2 attack: Submit a previously intercepted biometric data: replay**
- 0 **Type 3 attack: Compromising the feature extractor module to give results desired by attacker**
- 0 **Type 4 attack: Replace the genuine feature values produced by the system by fake values desired by attacker**
- 0 **Type 5 attack: Produce a high number of matching results**
- 0 **Type 6 attack: Attack the template database: add templates, modify templates etc.**

Biometric Terms: Verification and Identification

0 Verification

- User claims an identity for biometric comparison
- User then provides biometric data
- System tries to match the user's biometric with the large number of biometric data in the database
- Determines whether there is a match or a no match
- Network security utilizes this process

0 Identification

- User does not claim an identity, but gives biometric data
- System searches the database to see if the biometric provided is stored in the database
- Positive or negative identification
- Prevents from enrolling twice for claims
- Used to enter buildings

Biometric Process

- 0 **User enrolls in a system and provides biometric data**
- 0 **Data is converted into a template**
- 0 **Later on user provides biometric data for verification or identification**
- 0 **The latter biometric data is converted into a template**
- 0 **The verification/identification template is compared with the enrollment template**
- 0 **The result of the match is specified as a confidence level**
- 0 **The confidence level is compared to the threshold level**
- 0 **If the confidence score exceeds the threshold, then there is a match**
- 0 **If not, there is no match**

Biometric Technologies

- 0 **Finger scan: Fingerprint Image**
- 0 **Voice scan: Voice recording**
- 0 **Face scan: Facial image**
- 0 **Iris scan: Iris image**
- 0 **Retina scan: Retina image**
- 0 **Hand scan: Image of hand**
- 0 **Signature scan: Image of signature**
- 0 **Keystroke scan: Recording of character types**

Intrusion Detection/Prevention System

- 0 **An IDS is a device (or application) that monitors network and/or system activities for malicious activities or policy violations and produces reports to a Management Station.**
- 0 **Intrusion prevention is the process of performing intrusion detection and attempting to stop detected possible incidents.**
- 0 **Intrusion detection and prevention systems (IDPS) are primarily focused on identifying possible incidents, logging information about them, attempting to stop them, and reporting them to security administrators.**
- 0 **There are two main types of IDS's: network-based and host-based IDS.**
 - **In a network-based intrusion-detection system (NIDS), the sensors are located at choke points in the network to be monitored.**
 - **In a host-based system, the sensor usually consists of a software agent, which monitors all activity of the host on which it is installed, including file system, logs and the kernel.**

Threats to Access Control

- 0 **Dictionary Attack**
- 0 **Brute Force Attack**
- 0 **Spoofing at Logon**
- 0 **Phishing**
- 0 **Identity Theft**

Cryptography

- 0 **Definition of Cryptography**
- 0 **Important concepts**
 - **Symmetric and Asymmetric, Hash, Digital Signature etc.**
- 0 **Steganography and Digital watermarking**
- 0 **Attacks**

Definitions

- 0 **Cryptography**
 - **Mathematical manipulation of information that prevents the information being disclosed or altered**
- 0 **Cryptanalysis**
 - **Defeating the protected mechanisms of cryptography**
- 0 **Cryptology**
 - **Study of Cryptography and Cryptanalysis**

Goals of Cryptography

- 0 **Confidentiality**
- 0 **Integrity**
- 0 **Authenticity**
- 0 **Non-repudiation**
- 0 **Access Control**
- 0 **Make compromise difficult**

Process

- 0 **Input (also called Plaintext or Clear Text)**
- 0 **Cryptosystem (device that performs encryption/decryption)**
- 0 **Cryptographic Algorithms (Mathematical functions)**
- 0 **Output (Cipher text or Cryptogram)**
- 0 **Key (Crypto variable)**
- 0 **Key clustering: two different keys generate the same cipher text from the same plaintext, using the same cipher algorithm.**
 - **Need to choose the key in such a way to avoid key clustering**
 - **Need to make the job of the attacker as hard as possible**

Symmetric Key Cryptography

- 0 **Symmetric-key algorithms are a class of algorithms for cryptography that use trivially related, often identical, cryptographic keys for both decryption and encryption.**
- 0 **The encryption key is trivially related to the decryption key, in that they may be identical or there is a simple transformation to go between the two keys.**
- 0 **The keys, in practice, represent a shared secret between two or more parties that can be used to maintain a private information link.**
- 0 **The disadvantage of symmetric cryptography is that it presumes two parties have agreed on a key and been able to exchange that key in a secure manner prior to communication.**
- 0 **Symmetric algorithms are usually mixed with public key algorithms to obtain a blend of security and speed.**

Public Key Cryptography

- 0 **Public-key cryptography is a cryptographic approach which involves the use of asymmetric key algorithms instead of or in addition to symmetric key algorithms.**
- 0 **Unlike symmetric key algorithms, it does not require a secure initial exchange of one or more secret keys to both sender and receiver.**
- 0 **The asymmetric key algorithms are used to create a mathematically related key pair:**
 - **A secret private key and a published public key.**
 - **Use of these keys allows protection of the authenticity of a message by creating a digital signature of a message using the private key, which can be verified using the public key.**
- 0 **It also allows protection of the confidentiality and integrity of a message, by public key encryption, encrypting the message using the public key, which can only be decrypted using the private key.**
- 0 **Public key cryptography is widely used (e.g., TLS)**

Initialization Vector

- 0 **An initialization vector (IV) is a block of bits that is required to allow a stream (continuous bits) cipher or a block (fixed sized bits) cipher to be executed in any of several modes of operation to produce a unique stream independent from other streams produced by the same encryption key**
- 0 **The size of the IV depends on the encryption algorithm and on the cryptographic protocol in use and is normally as large as the block size of the cipher.**
- 0 **The IV must be known to the recipient of the encrypted information to be able to decrypt it.**

Digital Signature

- 0 **A digital signature or digital signature scheme is a mathematical scheme for demonstrating the authenticity of a digital message or document.**
- 0 **A valid digital signature gives a recipient reason to believe that the message was created by a known sender, and that it was not altered in transit.**
- 0 **Digital signatures are commonly used for software distribution, financial transactions, and in other cases where it is important to detect forgery and tampering.**
- 0 **Digital signatures are often used to implement electronic signatures.**
- 0 **Digital signatures employ a type of asymmetric cryptography.**
- 0 **Digital signature gives the receiver reason to believe the message was sent by the claimed sender.**
- 0 **Digital signatures can also provide non-repudiation.**

Certificate Authority

- 0 In cryptography, a certificate authority or certification authority (CA) is an entity that issues digital certificates for use by other parties.
- 0 It is an example of a trusted third party.
- 0 CAs are characteristic of many public key infrastructure (PKI) schemes.
- 0 Commercial CAs charge to issue certificates that will automatically be trusted by most web browsers
- 0 Aside from commercial CAs, some providers issue digital certificates to the public at no cost.
- 0 Large institutions or government entities may have their own CAs.

Public Key Infrastructure

- 0 **Public Key Infrastructure (PKI) is a set of hardware, software, people, policies, and procedures needed to create, manage, distribute, use, store, and revoke digital certificates.**
- 0 **A PKI is an arrangement that binds public keys with respective user identities by means of a certificate authority (CA).**
- 0 **The user identity must be unique within each CA domain.**
- 0 **The binding is established through the registration and issuance process.**
- 0 **The PKI role that assures this binding is called the Registration Authority (RA).**

Steganography

- 0 **Steganography is the art and science of writing hidden messages in such a way that no one, apart from the sender and intended recipient, suspects the existence of the message, a form of security through obscurity.**
- 0 **Generally, messages will appear to be something else: images, videos, text.**
- 0 **The advantage of steganography, over cryptography alone, is that messages do not attract attention to themselves.**
- 0 **A sender might start with an innocuous image file and adjust the color of every 100th pixel to correspond to a letter in the alphabet, a change so subtle that someone not specifically looking for it is unlikely to notice it.**

Digital Watermarking

- 0 **Digital watermarking is the process of embedding information into a digital signal in a way that is difficult to remove.**
- 0 **The signal may be audio, pictures or video, for example.**
- 0 **If the signal is copied, then the information is also carried in the copy.**
- 0 **In visible watermarking, the information is visible in the picture or video.**
- 0 **In invisible watermarking, information is added as digital data to audio, picture or video, but it cannot be perceived as such.**
- 0 **One application of watermarking is in copyright protection systems, which are intended to prevent or deter unauthorized copying of digital media.**

Attacks

- 0 **Brute Force**
- 0 **Birthday**
- 0 **Dictionary**
- 0 **Known Plaintext**
- 0 **Chosen Plaintext**
- 0 **Cipher text Only**
- 0 **Chosen Cipher text**

Security Architecture and Design

- 0 **Computer Architecture**
- 0 **Operating System**
- 0 **System Architecture**
- 0 **Security Architecture**
- 0 **Security Models**
- 0 **System Evaluation Methods**
- 0 **Some security threats**

Computer Architecture Components

- 0 **Central Processing Unit (CPU)**
- 0 **Registers**
- 0 **Memory Units**
- 0 **Input/output Processors**
- 0 **Single Processor**
- 0 **Multi-Processor**
- 0 **Multi-Core Architecture**
- 0 **Grids and Clouds**

Operating Systems

- 0 **Memory Management**
- 0 **Process management**
- 0 **File Management**
- 0 **Capability Domains**
- 0 **Virtual Machines**

System Architecture

- 0 **The software components that make up the system**
- 0 **Middleware**
- 0 **Database management**
- 0 **Networks**
- 0 **Applications**

Security Architecture

- 0 **Security critical components of the system**
- 0 **Trusted Computing Base**
- 0 **Reference Monitor and Security Kernel**
- 0 **Security Perimeter**
- 0 **Security Policy**
- 0 **Least Privilege**

Trusted Computing Base, Reference Monitor, Security Kernel

- 0 The trusted computing base (TCB) of a computer system is the set of all hardware, firmware, and/or software components that are critical to its security.
- 0 The goal is to reduce the size of the TCB so that the software can be verified.
- 0 In operating systems architecture, a reference monitor is a tamperproof, always-invoked, and small-enough-to-be-fully-tested-and-analyzed module that controls all software access to data objects or devices.
- 0 The reference monitor verifies that the request is allowed by the access control policy.

Security Models

- 0 **Bell and LaPadula (BLP) Confidentiality Model**
- 0 **Biba Integrity Model (opposite to BLP)**
- 0 **Clark Wilson Integrity Model**
- 0 **Information Flow Model**
- 0 **Non Interference Model**
- 0 **Graham Denning Model**
- 0 **Harrison-Ruzzo-Ullman Model**
- 0 **Lattice Model**

Bell and LaPadula

- 0 To determine whether a specific access mode is allowed, the clearance of a subject is compared to the classification of the object.
- 0 The clearance/classification scheme is expressed in terms of a lattice.
- 0 The model defines two mandatory access control (MAC) rules and one discretionary access control (DAC) rule with three security properties:
 - The Simple Security Property - a subject at a given security level may not read an object at a higher security level (no read-up).
 - The *-property (read "star"-property) - a subject at a given security level must not write to any object at a lower security level (no write-down).
 - The Discretionary Security Property - use of an access matrix to specify the discretionary access control.

Security Modes of Operation

- 0 **Dedicated**
- 0 **Systems High**
- 0 **Compartmented**
- 0 **Multilevel**
- 0 **Trust and Assurance**

Secure Systems Evaluation, Certification and Accreditation

- 0 **Secure system products have to be evaluated to determine if the vendors claims are real.**
- 0 **Typically a private nonprofit company (e.g., FFRDC) carries out the evaluation.**
- 0 **Various criteria have been developed for the evaluation.**
- 0 **Once the product is evaluated it has to be certified to work in your environment – i.e., your organization.**
- 0 **After all the testing is carried out and the organization feels that the product can be used securely, the senior management has to carry out accreditation – that is approve the use of the product in your environment.**

Secure System Evaluation: TCSEC

- o **Trusted Computer System Evaluation Criteria (TCSEC) is a United States Government Department of Defense (DoD) standard used to evaluate, classify and select computer systems being considered for the processing, storage and retrieval of sensitive or classified information.**
- o **The TCSEC, frequently referred to as the Orange Book, is the centerpiece of the DoD Rainbow Series publications (e.g., Purple book for evaluating database systems).**
- o **Initially issued in 1983 by the National Computer Security Center (NCSC), an arm of the National Security Agency, and then updated in 1985.**

Secure System Evaluation: ITSEC

- 0 **The Information Technology Security Evaluation Criteria (ITSEC) is a structured set of criteria for evaluating computer security within products and systems.**
- 0 **The ITSEC was first published in May 1990 in France, Germany, the Netherlands, and the United Kingdom based on existing work in their respective countries.**
- 0 **Levels E1 – E6**

Secure System Evaluation: Federal Criteria and the Common Criteria

- 0 **Other branches of the US government (e.g., NIST) also wanted to use secure systems and focus on a different set of criteria. Therefore, members of the US government (including the DoD) focused on developing the Federal Criteria (from the TCSEC) – this was in the early to mid 1990s**
- 0 **Around that time, there was interest to merge the US-based criteria with the EU based criteria - The Common Criteria for Information Technology Security Evaluation .**
- 0 **Levels: EAL 1 – EAL 7 (Evaluation Assurance Levels)**

Some Security Threats

- 0 **Buffer Overflow**
- 0 **Maintenance Hooks**
- 0 **Time of check / Time of use attacks**

APPENDIX

Network Security

- 0 **Introduction to Network Security**
- 0 **Types of Secure Network Systems**
- 0 **Secure Network Protocols**
- 0 **Network Forensics**
- 0 **Next Steps**

Network Security: Overview

- 0 **Network security consists of the provisions made in an underlying computer network infrastructure, policies adopted by the network administrator to protect the network and the network-accessible resources from unauthorized access.**
- 0 **Network security starts from authenticating the user, commonly with a username and a password.**
- 0 **Once authenticated, a firewall enforces access policies such as what services are allowed to be accessed by the network users.**
- 0 **Though effective to prevent unauthorized access, this component may fail to check potentially harmful content such as computer worms or Trojans being transmitted over the network.**
- 0 **Anti-virus software or an intrusion prevention system (IPS) help detect and inhibit the action of such malware.**
- 0 **An anomaly-based intrusion detection system may also monitor the network and traffic for unexpected (i.e. suspicious) content or behavior and other anomalies.**

Network Security: Overview

- 0 **Communication between two hosts using a network could be encrypted to maintain privacy.**
- 0 ***Honeypots* essentially decoy network-accessible resources, could be deployed in a network as surveillance and early-warning tools.**
- 0 **Techniques used by the attackers that attempt to compromise these decoy resources are studied during and after an attack to keep an eye on new exploitation techniques.**
- 0 **Such analysis could be used to further tighten security of the actual network being protected by the honeypot.**
- 0 **A Botnet is a collection of software agents, or robots, that run autonomously and automatically.**
- 0 **The term is most commonly associated with malicious software, but it can also refer to a network of computers using distributed computing software.**

Intrusion Detection Systems

- 0 **An intrusion can be defined as “any set of actions that attempt to compromise the integrity, confidentiality, or availability of a resource”.**
- 0 **Attacks are:**
 - **Host-based attacks**
 - **Network-based attacks**
- 0 **Intrusion detection systems are split into two groups:**
 - **Anomaly detection systems**
 - **Misuse detection systems**
- 0 **Use audit logs**
 - **Capture *all* activities in network and hosts.**
 - **But the amount of data is huge!**

OSI Model

- 0 The Physical Layer defines the electrical and physical specifications for devices. In particular, it defines the relationship between a device and a physical medium.
- 0 This includes the layout of pins, voltages, cable specifications, hubs, repeaters, network adapters, host bus adapters, etc.
- 0 The Data Link Layer provides the functional and procedural means to transfer data between network entities and to detect and possibly correct errors that may occur in the Physical Layer.
- 0 The Network Layer provides the functional and procedural means of transferring variable length data sequences from a source to a destination via one or more networks.
- 0 The Network Layer performs network routing functions, and might also perform fragmentation and reassembly, and report delivery errors.
- 0 Routers operate at this layer—sending data throughout the extended network and making the Internet possible.

OSI Model

- 0 **The Transport Layer provides transparent transfer of data between end users, providing reliable data transfer services to the upper layers.**
- 0 **The Transport Layer controls the reliability of a given link through flow control, segmentation/desegmentation, and error control.**
- 0 **Some protocols are state and connection oriented.**
- 0 **This means that the Transport Layer can keep track of the segments and retransmit those that fail.**
- 0 **Although not developed under the OSI Reference Model and not strictly conforming to the OSI definition of the Transport Layer, typical examples of Layer 4 are the Transmission Control Protocol (TCP) and User Datagram Protocol (UDP).**

OSI Model

- 0 The Session Layer controls the dialogues (connections) between computers.
- 0 It establishes, manages and terminates the connections between the local and remote application.
- 0 It provides for full-duplex, half-duplex, or simplex operation, and establishes checkpointing, adjournment, termination, and restart procedures.
- 0 Presentation layer provides independence from differences in data representation (e.g., encryption) by translating from application to network format, and vice versa.
- 0 The presentation layer works to transform data into the form that the application layer can accept.
- 0 This layer formats and encrypts data to be sent across a network, providing freedom from compatibility problems. It is sometimes called the syntax layer.

Application Layer (Examples)

- 0 **DNS, Domain Name System (Service) Protocol**
- 0 **FTAM, File Transfer Access and Management**
- 0 **FTP, File Transfer Protocol**
- 0 **HTTP, Hypertext Transfer Protocol**
- 0 **IMAP, IMAP4, Internet Message Access Protocol**
- 0 **LDAP, Lightweight Directory Access Protocol**
- 0 **MIME (S-MIME), Multipurpose Internet Mail Extensions and Secure MIME**
- 0 **NFS, Network File System**
- 0 **SMTP, Simple Mail Transfer Protocol**
- 0 **TELNET, Terminal Emulation Protocol of TCP/IP**
- 0 **VTP, Virtual Terminal Protocol**
- 0 **X.500, Directory Access Protocol (DAP)**

TCP/IP

- 0 In the TCP/IP model of the Internet, protocols are not as rigidly designed into strict layers as the OSI model.
- 0 The Internet Application Layer includes the OSI Application Layer, Presentation Layer, and most of the Session Layer.
- 0 Its end-to-end Transport Layer includes the graceful close function of the OSI Session Layer as well as the OSI Transport Layer.
- 0 The internetworking layer is a subset of the OSI Network Layer
- 0 Link Layer includes the OSI Data Link and Physical Layers, as well as parts of OSI's Network Layer.

IPv4

- 0 **Internet Protocol version 4 (IPv4) is the fourth revision in the development of the Internet Protocol (IP) and it is the first version of the protocol to be widely deployed.**
- 0 **Together with IPv6, it is at the core of standards-based internetworking methods of the Internet.**
- 0 **IPv4 is still by far the most widely deployed Internet Layer protocol.**
- 0 **IPv4 is a connectionless protocol for use on packet-switched Link Layer networks (e.g., Ethernet).**
- 0 **It operates on a best effort delivery model, in that it does not guarantee delivery, nor does it assure proper sequencing, or avoid duplicate delivery.**
- 0 **These aspects, including data integrity, are addressed by an upper layer transport protocol (e.g., Transmission Control Protocol).**

IPSEC

- 0 **Internet Protocol Security (IPsec) is a protocol suite for securing Internet Protocol (IP) communications by authenticating and encrypting each IP packet of a data stream.**
- 0 **IPsec also includes protocols for establishing mutual authentication between agents at the beginning of the session and negotiation of cryptographic keys to be used during the session.**
- 0 **IPsec can be used to protect data flows between a pair of hosts (e.g. computer users or servers), between a pair of security gateways (e.g. routers or firewalls), or between a security gateway and a host**
- 0 **IPsec is a dual mode, end-to-end, security scheme operating at the Internet Layer of the Internet Protocol Suite or OSI model Layer 3.**
- 0 **Some other Internet security systems in widespread use, such as Secure Sockets Layer (SSL), Transport Layer Security (TLS) and Secure Shell (SSH), operate in the upper layers of these models.**
- 0 **Hence, IPsec can be used for protecting any application traffic across the Internet.**

TLS/SSL

- 0 **Transport Layer Security (TLS) and its predecessor, Secure Socket Layer (SSL), are cryptographic protocols that provide security for communications over networks such as the Internet.**
- 0 **TLS and SSL encrypt the segments of network connections at the Application Layer to ensure secure end-to-end transit at the Transport Layer.**
- 0 **Several versions of the protocols are in widespread use in applications like web browsing, electronic mail, Internet faxing, instant messaging and voice-over-IP (VoIP).**
- 0 **The TLS protocol allows client/server applications to communicate across a network in a way designed to prevent eavesdropping and tampering.**
- 0 **TLS provides endpoint authentication and communications confidentiality over the Internet using cryptography. TLS provides RSA security.**

DMZ

- 0 **DMZ, or demilitarized zone is a physical or logical subnetwork that contains and exposes an organization's external services to a larger untrusted network (e.g., Internet).**
- 0 **The purpose of a DMZ is to add an additional layer of security to an organization's Local Area Network (LAN); an external attacker only has access to equipment in the DMZ, rather than any other part of the network.**
- 0 **In a network, the hosts most vulnerable to attack are those that provide services to users outside of the local area network, such as e-mail, web and DNS servers.**
- 0 **Because of the increased potential of these hosts being compromised, they are placed into their own sub-network in order to protect the rest of the network if an intruder were to succeed.**
- 0 **Hosts in the DMZ have limited connectivity to specific hosts in the internal network, though communication with other hosts in the DMZ and to the external network is allowed.**
- 0 **This allows hosts in the DMZ to provide services to both the internal and external network, while an intervening firewall controls the traffic between the DMZ servers and the internal network clients.**

VPN

- 0 **A virtual private network (VPN) is a network that uses a public telecommunication infrastructure, such as the Internet, to provide remote offices or individual users with secure access to their organization's network.**
- 0 **It aims to avoid an expensive system of owned or leased lines that can only be used by one organization.**
- 0 **The goal of a VPN is to provide the organization with the same, secure capabilities, but at a much lower cost.**
- 0 **It encapsulates data transfers between two or more networked devices not on the same private network so as to keep the transferred data private from other devices on one or more intervening local or wide area networks.**
- 0 **There are many different classifications, implementations, and uses for VPNs.**

What is Network Forensics?

- 0 Network forensics is the capture, recording, and analysis of network events in order to discover the source of security attacks or other problem incidents.
- 0 Network forensics systems can be one of two kinds:
 - ***"Catch-it-as-you-can" systems***, in which all packets passing through a certain traffic point are captured and written to storage with analysis being done subsequently in batch mode.
 - = This approach requires large amounts of storage, usually involving a RAID system.
 - ***"Stop, look and listen" systems***, in which each packet is analyzed in a rudimentary way in memory and only certain information saved for future analysis.
 - = This approach requires less storage but may require a faster processor to keep up with incoming traffic.

Network Forensics Analysis Tools (NFAT): Relationships between IDS, Firewalls and NFAT

80

- 0 **IDS attempts to detect activity that violates an organization's security policy by implementing a set of rules describing preconfigures patterns of interest**
- 0 **Firewall allows or disallows traffic to or from specific networks, machine addresses and port numbers**
- 0 **NFAT synergizes with IDSs and Firewalls.**
 - **Preserves long term record of network traffic**
 - **Allows quick analysis of trouble spots identified by IDSs and Firewalls**
- 0 **NFATs must do the following:**
 - **Capture network traffic**
 - **Analyze network traffic according to user needs**
 - **Allow system users discover useful and interesting things about the analyzed traffic**

Honeynets/Honeypots

- 0 **Network Forensics and honeynet systems have the same features of collecting information about computer misuses**
- 0 **Honeynet system can lure attackers and gain information about new types of intrusions**
- 0 **Network forensics systems analyze and reconstruct the attack behaviors**
- 0 **These two systems integrated together build a active self learning and response system to profile the intrusion behavior features and investigate the original source of the attack.**
- 0 **Note that while Honeynets operate at the network level, Honeypots operate at the host level.**

Legal and Forensics

- 0 **International and Legal Issues**
- 0 **Incident Management**
- 0 **Computer Forensics**
- 0 **Compliance**

International and Legal Issues

0 Jurisdiction

- Law, economics, beliefs and politics
- Sovereignty of nations

0 International Cooperation

- Initiatives related to international cooperation in dealing with computer crime
- The Council of Europe (CoE) Cybercrime Convention

0 Intellectual Property Protection

- Organizations must protect intellectual property (IP)
 - = Theft
 - = Loss
 - = Corporate espionage
 - = Improper duplication
- Intellectual property must have value
 - = Organization must demonstrate actions to protect IP

Privacy

- 0 **Personally Identifiable Information**
 - Identify or locate, Not anonymous
- 0 **Privacy Laws and Regulations**
 - Rights and obligations of Individuals, Organizations
- 0 **International Privacy**
 - Organization for Economic Co-operation and Development (OECD)
- 0 **Privacy Law Examples**
 - Health Insurance Portability and Accountability Act (HIPAA)
 - Personal Information Protection and Electronics Document Act (PIPEDA)
 - European Union Data Protection Directive
- 0 **Employee Privacy**
 - Employee monitoring: Authorized usage policies, Internet usage, Email. Telephone

Digital Forensics

0 Collection of Digital Evidence

- Volatile and fragile; Short life span; Collect quickly; Document

0 Chain of Custody for Evidence

- Who; What; When; Where; How

0 Investigation Process

- Identify suspects; Identify witnesses; Identify system; Identify team; Search warrants

0 Evidence

- Hearsay: Second hand evidence; Normally not admissible
- Business records exception: Computer generated information; Process of creation description

0 Reporting and Documentation

0 Communication About the Incident

Compliance

0 Key Aspects

- Knowing legislation
- Following legislation

0 Regulatory Environment Examples

- Sarbanes-Oxley (SOX))
- Gramm-Leach-Bliley Act (GLBA)
- Basel II

0 Compliance Audit

- Audit = a formal written examination of controls
- Auditor role = 3rd party evaluator
- Continuous auditing = automation
- Document the audit procedure

Other Aspects of Cyber Security

- 0 **Business Continuity Planning**
- 0 **Operations Security**
- 0 **Physical Security**
- 0 **Database, Applications and Applications Development Security**

Business Continuity Planning

- 0 **Project Scope Development and Planning**
- 0 **Business Impact Analysis (BIA) and Functional Requirements**
- 0 **Business Continuity and Recovery Strategy**
- 0 **Plan Design and Development**
- 0 **Implementation**
- 0 **Restoration / Disaster Recovery**
- 0 **Feedback and Plan Management**

Physical Security

- 0 **Site and Facility Design Criteria**
- 0 **Perimeter Security**
- 0 **Building and Inside Security**
- 0 **Secure Operational Area**
- 0 **E.g., Protecting from Fire, Hurricanes, HVAC etc.**

Operations Security

- 0 **Resource Protection**
- 0 **Continuity of Operations**
- 0 **Change Control Management**
- 0 **Privileged Entity Control**
- 0 **Patch Management**
- 0 **Appropriate Storage Devices**

Database, Applications and Applications Development Security

- 0 **Securing the databases (e.g., access control models)**
- 0 **Securing Applications (e.g., Social media systems)**
- 0 **Systems Lifecycle Security**
- 0 **Secure Software Development**
- 0 **Secure software engineering (e.g., secure software testing)**
- 0 **Coding Errors and Malware Attacks**

Coding Errors and Malware Attacks

0 Coding Errors

- Buffer overflow
- Cross-site scripting XSS
- Dangling pointer
- Invalid hyperlink
- Secure web applications
- - - - -

0 Malware Attacks

- SQL Injection
- Malicious file execution
- Denial of service
- Hijacking
- Phishing
- - - - -